E-MOBILIER

PLATEFORME IMMOBILIÈRE & D'HÉBERGEMENTS — RÉPUBLIQUE DU BÉNIN

DOCUMENT D'INGÉNIERIE & SPÉCIFICATIONS CONFIDENTIEL

Spécifications Techniques Backend & Architecture de Sécurité

Plan Directeur Exhaustif : Rôles & Permissions (RBAC/ABAC), Cloisonnement Financier Zero-Trust, Dispositif Anti-Contournement, Moteur Multi-Canal & Couverture Intégrale des Opérations Métier.

COMMANDITAIRE & DÉCISIONNAIRE LÉGAL

MAGNIDE Justin

Super Administrateur Principal (Propriétaire)

RESPONSABLE ARCHITECTURE & TECHNIQUE

Jean-Paul GNIKPO

Super Administrateur Technique (Lead Backend)

VERSION & STATUT DOCUMENTAIRE

Version 2.0 (Consolidée)

5 Phases Fondations + 5 Briques Opérationnelles

PÉRIMÈTRE D'AUDIT SPÉCIALISÉ

Préparation Pentest

Référentiel de conformité pour l'auditrice en sécurité

E-Mobilier — Architecture Logicielle & Spécifications REST API

Date d'édition : Novembre 2026

1. Principes Directeurs d'Architecture & Sécurité

Le présent document formalise les spécifications techniques et fonctionnelles exhaustives du backend de la plateforme **E-Mobilier**. Il répond aux conclusions du compte-rendu de direction entre M. Justin MAGNIDE et M. Jean-Paul GNIKPO, en couvrant à la fois les impératifs de sécurité (ségrégation des pouvoirs, protection de la trésorerie, étanchéité des données clients) et les réalités opérationnelles quotidiennes (conduite des visites, modération du catalogue, traitement des recherches, agrément des agents).

> **Règle Fondatrice d'Étanchéité :** Les interfaces visuelles et navigateurs sont considérés comme non fiables par défaut. Aucune règle de sécurité, de masquage de coordonnées ou de limitation financière ne doit dépendre du frontend. Toutes les contraintes sont rigoureusement appliquées et verrouillées côté serveur d'API (routes, contrôleurs, requêtes SQL et sérialiseurs JSON).

Les Cinq Piliers d'Architecture Backend :

1. **Ségrégation Stricte des Fonctions (Segregation of Duties) :** Découpage strict des rôles empêchant toute concentration de pouvoirs. Le volet financier et la trésorerie sont l'apanage exclusif du Propriétaire légal. L'administration technique gère le système sans aucune visibilité sur les finances.
2. **Cloisonnement Financier Zero-Trust :** Isolation des tables financières, vérification double (rôle + identifiant propriétaire figé), et exécution des retraits (Payouts) exclusivement vers le compte de l'entreprise après authentification renforcée (OTP).
3. **Dispositif Anti-Contournement Hermétique :** Les profils opérationnels (Secrétaire, Responsables de zone) traitent les dossiers sans jamais voir les téléphones, e-mails ni noms commerciaux des demandeurs, qui sont supprimés de la charge utile JSON à la source.
4. **Cloisonnement Territorial Automatique (ABAC par Zone) :** Les Responsables de zone sont bornés à leur secteur géographique via une injection de portée globale (Global Scope) au niveau du moteur de requêtes.
5. **Résilience & Asynchronisme :** Découplage complet des flux critiques (paiement, génération PDF, SMS, WhatsApp) via des files d'attente à priorités avec politique de réessai automatique (Exponential Backoff) et repli multi-canal.

2. Matrice Complète des Rôles & Permissions (RBAC / ABAC)

Le système structure quatre profils d'administration interne distincts, venant encadrer les rôles publics (`Client` , `Agent mobilier`).

DOMAINE FONCTIONNEL / ACTION BACKEND	SUPER ADMIN PRINCIPAL (MAGNIDE JUSTIN)	SUPER ADMIN TECHNIQUE (JEAN-PAUL GNIKPO)	SECRÉTAIRE (ADMIN SECONDAIRE)	RESPONSABLE DE ZONE (ADMIN SECONDAIRE)
Catalogue : Création & édition d'annonces	Total	Total	Total	Sa Zone Uniquement
Catalogue : Modération & mise en ligne (Validation/Rejet)	Validation Finale	Support Tech	Validation Opérationnelle	**Interdit** (Soumission seule)
Catalogue : Titres fonciers & documents légaux	Accès Total	Maintenance Fichiers	Lecture Streamée (Contrôle)	**Interdit**
Visites : Consultation des plannings et dossiers	Total (Contacts clairs)	Total (Contacts clairs)	Total (Contacts masqués)	Sa Zone (Contacts masqués)
Visites : Planification, compte-rendu terrain & clôture	Arbitrage Final	Audit Logs	Affectation / Coordination	Exécution Terrain & Saisie
Anti-Contournement : Coordonnées & noms demandeurs	En Clair Natif	En Clair Natif	**Masqué par Défaut**	**Masqué par Défaut**
Anti-Contournement : Demande d'accès temporaire (TTL)	*Non concerné*	*Non concerné*	Peut Demander	Peut Demander (Sa Zone)

DOMAINE FONCTIONNEL / ACTION BACKEND	SUPER ADMIN PRINCIPAL (MAGNIDE JUSTIN)	SUPER ADMIN TECHNIQUE (JEAN-PAUL GNIKPO)	SECRÉTAIRE (ADMIN SECONDAIRE)	RESPONSABLE DE ZONE (ADMIN SECONDAIRE)
Anti-Contournement : Approbation / Révocation de démasquage	Approbation / Révocation	Approbation / Révocation	Interdit	Interdit
Finance : Soldes, Grand Livre, CA, transactions	MONOPOLE EXCLUSIF	INTERDIT STRICT (403)	INTERDIT STRICT (403)	INTERDIT STRICT (403)
Finance : Retraits (Payouts) vers compte entreprise	EXCLUSIF (Validation OTP)	INTERDIT STRICT (403)	INTERDIT STRICT (403)	INTERDIT STRICT (403)
Partenaires : Agrément KYC des Agents Mobiliers	Arbitrage	Support Système	Instruction & Vérification	Interdit
Système : Infrastructure, Queues, Health Check, Logs	Vue Globale	Administration Complète	Interdit	Interdit

3. Spécifications Détaillées des 5 Phases Initiales (Fondations, Sécurité & Finance)

PHASE 1 : Fondations RBAC, Gouvernance des Comptes, Cloisonnement & Conformité Légale

Cette phase remplace le rôle générique actuel par une structure de gouvernance hermétique, empêche l'auto-élévation de privilèges et pose le cadre juridique obligatoire.

NOTIONS INDISPENSABLES D'IMPLÉMENTATION BACKEND :

- **ABAC + RBAC Hybride :** Attribution d'un rôle d'administration combiné à un identifiant contextuel territorial (`zone_id`) évalué à chaque requête.
- **Root Owner Binding & Anti-Privilege Escalation :** Liaison immuable du compte de MAGNIDE Justin à une variable système non modifiable via l'API. L'API d'administration interdit au Super Admin Technique de s'attribuer le rôle principal ou une permission financière.
- **Append-Only Audit Logging :** Table d'audit protégée contre toute modification/suppression SQL, consignant chaque opération sensible avec empreinte de session.
- **Log Scrubber / Sanitizer :** Intercepteur dans le canal de logs serveur qui masque automatiquement les clés sensibles (`montant` , `solde` , `secret_key` , `otp`) pour que la maintenance technique n'expose aucune donnée financière.
- **Preuve d'Acceptation Numérique (CGU & Charte) :** Stockage immuable de l'empreinte de la version du document légal signée par l'agent ou le client avec horodatage certifié.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
GET	`/api/admin/zones`	Tous les Administrateurs	Retourne le référentiel des zones géographiques actives (communes, départements, secteurs).
POST	`/api/admin/zones`	Super Admin Principal, Super Admin Tech	Crée une nouvelle zone géographique avec code cadastral et découpage administratif.
PATCH	`/api/admin/zones/{id}`	Super Admin Principal, Super Admin Tech	Modifie les limites géographiques ou active/désactive une zone.
GET	`/api/admin/utilisateurs`	Super Admin Principal, Super Admin Tech	Liste les comptes d'administration avec leurs rôles, statuts et zones de rattachement.
POST	`/api/admin/utilisateurs`	Super Admin Principal, Super Admin Tech	Crée un compte administrateur secondaire ou technique. **Rejet 403 strict** si tentative de créer un compte avec rôle Principal.
PATCH	`/api/admin/utilisateurs/{id}/role-zone`	Super Admin Principal, Super Admin Tech	Modifie l'affectation de rôle ou de zone. **Rejet 403 + Alerte de sécurité** si le compte cible est celui de MAGNIDE Justin.
POST	`/api/admin/utilisateurs/{id}/statut`	Super Admin Principal, Super Admin Tech	Suspend ou réactive un compte. Révoque instantanément l'intégralité des jetons Sanctum actifs du compte ciblé.
GET	`/api/cgu/courante`	Public / Authentifié	Délivre la dernière version en vigueur des CGU avec identifiant de version et empreinte hash.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
POST	`/api/admin/cgu`	Super Admin Principal, Super Admin Tech	Publie une nouvelle mouture des CGU ou de la Charte de Non-Contournement.
POST	`/api/admin/charte/signer`	Secrétaire, Responsable de zone	Consigne la signature numérique de la Charte de Non-Contournement. Conditionne l'accès aux routes d'administration.
GET	`/api/admin/audit-logs`	Super Admins (Vue technique purgée pour Tech)	Consultation du journal d'audit immuable avec filtrage automatique des métadonnées financières pour le Super Admin Tech.
GET	`/api/tech/system-health`	Super Admin Tech, Super Admin Principal	Rapport d'état sur l'infrastructure (charge CPU, connectivité BDD, latence cache, files d'attente). Zéro donnée financière.

PHASE 2 : Dispositif Anti-Contournement, Masquage Dynamique & Workflow de Démasquage

Cette phase garantit que les coordonnées clients ne quittent jamais le serveur pour les administrateurs secondaires, tout en fournissant une procédure d'exception bornée dans le temps.

NOTIONS INDISPENSABLES D'IMPLÉMENTATION BACKEND :

- **Sérialisation Conditionnelle (Context-Aware API Resources) :** Remplacement systématique à la sérialisation des téléphones, e-mails et raisons sociales par `"MASQUÉ"` pour la Secrétaire et les Responsables de zone.
- **Global Query Scope (Filtrage Territorial) :** Injection systématique de la contrainte `WHERE zone_id = user.zone_id` pour le Responsable de zone sur toutes les requêtes de biens, demandes et visites.
- **Protection Anti-IDOR (Insecure Direct Object Reference) :** Blocage déterministe de toute consultation d'un dossier dont la zone ne correspond pas à l'agent connecté.
- **Time-Bound Access Grant (TTL) :** Autorisation temporaire d'accès à durée de vie paramétrable (ex. 120 minutes) devenant caduque au millième de seconde sans nécessiter de cron de nettoyage.
- **Read-Access Auditing & Anti-Scraping Throttling :** Journalisation de chaque lecture de coordonnée en clair et limitation stricte du nombre de requêtes par minute.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
GET	`/api/admin/demandes-clients`	Super Admins (Clair), Secrétaire (Masqué), Resp. Zone (Zone + Masqué)	Liste paginée des demandes de recherche. Les numéros de téléphone et e-mails sont purgés du flux JSON pour les profils secondaires.
GET	`/api/admin/demandes-clients/{id}`	Super Admins (Clair), Secrétaire (Masqué), Resp. Zone (Zone + Masqué)	Fiche détaillée de la demande client. Masquage automatique des coordonnées du demandeur et statut de paiement sans montant.
GET	`/api/admin/visites`	Super Admins (Clair), Secrétaire (Masqué), Resp. Zone (Zone + Masqué)	Liste des visites de parcelles/biens. Filtrage automatique par zone pour le Responsable de zone et occultation des coordonnées client.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
PATCH	`/api/admin/visites/{id}/statut`	Tous les Admins (Resp. Zone limité à sa zone)	Mise à jour opérationnelle du statut de la visite (`Programmée` , `Effectuée` , `Reportée` , `Clôturée`).
POST	`/api/admin/visites/{id}/assigner-zone`	Super Admins, Secrétaire	Assigne une visite à un Responsable de zone spécifique selon le secteur géographique du bien.
POST	`/api/admin/demasquages/demander`	Secrétaire, Responsable de zone	Initie une demande formelle de démasquage en spécifiant le dossier cible, le motif prédéfini et une justification circonstanciée.
GET	`/api/admin/demasquages/mes-demandes`	Secrétaire, Responsable de zone	Consulte l'historique et l'état d'instruction de ses propres requêtes de démasquage.
GET	`/api/admin/demasquages/en-attente`	Super Admin Principal, Super Admin Tech	File d'attente d'arbitrage des demandes de démasquage soumises par les équipes secondaires.
POST	`/api/admin/demasquages/{id}/approuver`	Super Admin Principal, Super Admin Tech	Approuve la demande en fixant la durée de validité en minutes (calcul du timestamp `expires_at`).
POST	`/api/admin/demasquages/{id}/refuser`	Super Admin Principal, Super Admin Tech	Rejette la demande d'accès avec motif d'opposition consigné dans l'audit.
POST	`/api/admin/demasquages/{id}/revoquer`	Super Admin Principal, Super Admin Tech	Révoque immédiatement une autorisation en cours avant son terme naturel.
GET	`/api/admin/dossiers/{type}/{id}/coordonnees`	Secrétaire & Resp. Zone (avec TTL valide), Super Admins	**Point critique :** Vérifie la validité temporelle de l'approbation (`now < expires_at`), journalise l'accès et délivre les coordonnées pour ce dossier unitaire.

PHASE 3 : Isolation Financière Zero-Trust, Intégration KKiaPay/FedaPay & Coffre-Fort des Retraits

Cette phase sanctuarise le volet financier sous l'autorité exclusive de MAGNIDE Justin, fiabilise les encaissements via webhooks réconciliés et sécurise les décaissements par validation OTP.

NOTIONS INDISPENSABLES D'IMPLÉMENTATION BACKEND :

- **Financial Vault Middleware (Subject Pinning) :** Intercepteur rejetant avec code 403 toute requête financière n'émanant pas de l'identifiant strict de MAGNIDE Justin.
- **Server-Side Price Authority :** Le client ne transmet aucun montant ; le backend détermine le prix officiel depuis la BDD (50 FCFA déblocage, 500 FCFA visite, loyer hébergement).
- **HMAC Signature Verification & Idempotence :** Validation de la signature cryptographique du webhook et verrouillage pessimiste SQL (`SELECT ... FOR UPDATE`) pour bloquer les doublons.
- **Réconciliation Active Serveur-à-Serveur :** Interrogation systématique de l'API de l'agrégateur pour valider le statut `SUCCESS` , la devise `XOF` et le montant exact au centime près.
- **Grand Livre en Partie Double (Immutable Ledger) :** Le solde résulte de la somme arithmétique d'écritures immuables de crédit (encaissements nets) et de débit (retraits validés).
- **Payout avec Liste Blanche & Dynamic Linking OTP :** Destination de virement figée côté serveur (compte entreprise Justin). Code OTP à 6 chiffres lié cryptographiquement au montant, valable 3 minutes.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
POST	`/api/paiements/initier`	Client, Agent mobilier	Génère une intention de paiement (contrôle l'acceptation des CGU, fixe le tarif officiel côté serveur et crée la référence interne).
POST	`/api/kkiapay/webhook`	Public (Signé HMAC Agrégateur)	Vérifie la signature HMAC, applique le verrou d'idempotence, réconcilie avec l'API KKiaPay et met à jour le dossier et le Grand Livre.
POST	`/api/kkiapay/verify`	Client, Agent mobilier	Déclenche la réconciliation serveur-à-serveur idempotente suite au retour du widget de paiement côté client.
GET	`/api/paiements/{ref}/recu`	Client Propriétaire, Justin MAGNIDE	Génère et délivre le reçu officiel au format PDF avec signature d'intégrité.
GET	`/api/finance/tableau-de-bord`	**MAGNIDE Justin UNIQUEMENT**	Solde disponible, solde en compensation, chiffre d'affaires cumulé et ventilation. **Rejet 403 + Alerte** pour tout autre profil.
GET	`/api/finance/transactions`	**MAGNIDE Justin UNIQUEMENT**	Grand Livre comptable complet des flux monétaires (montants bruts, commissions prélevées, montants nets crédités).
GET	`/api/finance/transactions/export`	**MAGNIDE Justin UNIQUEMENT**	Export certifié des écritures comptables sous formats CSV et PDF.
GET	`/api/finance/webhooks`	**MAGNIDE Justin UNIQUEMENT**	Journal exhaustif des webhooks financiers reçus avec charges utiles intégrales et diagnostics de réconciliation.
GET	`/api/finance/retraits`	**MAGNIDE Justin UNIQUEMENT**	Historique des ordres de virement vers le compte d'entreprise et état de compensation.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
POST	`/api/finance/retraits/initier`	**MAGNIDE Justin UNIQUEMENT**	Vérifie le solde disponible, crée un ordre de virement vers le compte en liste blanche (état `EN_ATTENTE_OTP`) et expédie l'OTP.
POST	`/api/finance/retraits/{id}/confirmer-otp`	**MAGNIDE Justin UNIQUEMENT**	Contrôle l'OTP, exécute l'ordre de décaissement auprès de l'agrégateur et passe le virement en statut `EXÉCUTÉ`.
POST	`/api/finance/retraits/{id}/annuler`	**MAGNIDE Justin UNIQUEMENT**	Annule une demande de retrait non encore validée par OTP et libère la réserve de solde.
GET	`/api/tech/webhooks/health`	Super Admin Tech, Super Admin Principal	Moniteur technique des webhooks : horodatage, code statut HTTP, validité signature, latence réseau. **Zéro montant, zéro solde.**

PHASE 4 : Moteur de Notifications Multi-Canal Asynchrone & Résilience

Cette phase assure la distribution temps réel des confirmations de paiement et des alertes de retrait sur WhatsApp, SMS, E-mail et Push, avec un filtrage étanche des contenus selon les profils.

NOTIONS INDISPENSABLES D'IMPLÉMENTATION BACKEND :

- **Domain Events & AfterCommit Dispatching :** Émission des événements de notification uniquement après validation définitive (commit SQL) de la transaction financière.
- **Architecture à Trois Paliers de Files d'Attente :**
  - `critique-securite` (Priorité 1) : Codes OTP et alertes financières de Justin (latence cible < 3s).
  - `notifications-paiement` (Priorité 2) : Confirmations WhatsApp/SMS clients et alertes administrateurs.
  - `documents-emails` (Priorité 3) : Reçus PDF comptables et courriels récapitulatifs.
- **Modèles de Messages Cloisonnés :**
  - *Justin MAGNIDE :* Montant net, solde disponible, référence et coordonnées client complètes.
  - *Client :* Code de réservation, montant acquitté et reçu téléchargeable.
  - *Admins Secondaires :* Changement d'état opérationnel (`Payé / Validé`) **sans montant ni coordonnées client**.
- **Exponential Backoff & Repli WhatsApp → SMS :** Reprise échelonnée sur incident (0s, 15s, 60s, 5m, 15m) et bascule automatique sur SMS transactionnel dès le 2e échec WhatsApp.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
POST	`/api/user/device-token`	Tous les Utilisateurs Authentifiés	Enregistre ou actualise le jeton Push (Web/Mobile) rattaché au rôle et à la zone de l'utilisateur.
DELETE	`/api/user/device-token`	Tous les Utilisateurs Authentifiés	Supprime le jeton de notification Push lors de la déconnexion de l'appareil.
GET	`/api/notifications`	Tous les Utilisateurs Authentifiés	Retourne le fil interne des alertes (filtré hermétiquement : montants inclus pour Justin, statuts seuls pour les secondaires).
POST	`/api/notifications/{id}/lire`	Tous les Utilisateurs Authentifiés	Marque une notification interne comme lue.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
GET	`/api/finance/notifications/audit`	**MAGNIDE Justin UNIQUEMENT**	Journal exhaustif des notifications financières expédiées (WhatsApp, SMS, Email, Push) avec statuts de réception et montants.
GET	`/api/tech/notifications/logs`	Super Admin Tech, Super Admin Principal	Journal technique des canaux d'envoi (taux de succès, délais de livraison, erreurs réseau). Contenu financier purgé.
POST	`/api/tech/notifications/{id}/relancer`	Super Admin Tech, Super Admin Principal	Réinjecte dans la file d'attente une notification en échec définitif (Dead Letter Queue) sans exposer son contenu monétaire.

PHASE 5 : Durcissement Backend, Scellement Cryptographique & Préparation à l'Audit

Cette phase verrouille l'intégrité de la base de données contre les altérations manuelles directes et met à disposition des coupe-circuits d'urgence.

NOTIONS INDISPENSABLES D'IMPLÉMENTATION BACKEND :

- **Application-Layer Intrusion Detection (Tripwire) :** Toute requête non autorisée vers les endpoints `/api/finance/*` ou tentative de modification du compte de Justin déclenche instantanément une alerte critique prioritaire via WhatsApp.
- **Scellement Cryptographique du Grand Livre (HMAC Hash Chaining) :** Chaque écriture financière intègre une signature calculée à partir de ses données, de la signature précédente et d'une clé secrète dédiée. Toute modification directe en base rompt la chaîne et bloque les retraits.
- **Coupe-Circuit Applicatif (Kill-Switch) :** Drapeau atomique permettant à MAGNIDE Justin de suspendre instantanément tout décaissement ou de révoquer l'ensemble des démasquages en cours en un clic.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
POST	`/api/finance/securite/verifier-integrite`	**MAGNIDE Justin UNIQUEMENT**	Parcourt l'ensemble de la chaîne cryptographique du Grand Livre et certifie l'absence de falsification en base de données.
POST	`/api/finance/securite/geler-retraits`	**MAGNIDE Justin UNIQUEMENT**	Coupe-circuit immédiat suspendant tous les ordres de décaissement (Kill-Switch).
POST	`/api/admin/securite/revoquer-tous-demasquages`	Super Admin Principal, Super Admin Tech	Révocation d'urgence immédiate de toutes les autorisations de démasquage actives sur l'ensemble des administrateurs secondaires.
GET	`/api/admin/securite/alertes`	Justin (Intégral), Tech (Hors son compte)	Consulte le journal des alertes d'intrusion (violations RBAC, tentatives d'escalade, abus de quotas anti-scraping).

Cahier des Charges pour l'Étudiante Spécialisée en Sécurité (Surface d'Attaque Backend)

CODE TEST	SURFACE D'ATTAQUE CIBLÉE	SCÉNARIO DE TEST À EXÉCUTER PAR L'AUDITRICE	RÉSULTAT ATTENDU (CRITÈRE DE SUCCÈS)
SEC-01	Étanchéité Financière vs Admin Tech	Tenter d'appeler les routes `/api/finance/*` avec le token du Super Admin Technique.	Rejet 403 systématique + Notification d'alerte immédiate sur le WhatsApp de Justin.
SEC-02	Escalade de Privilèges	Depuis le compte Admin Tech, tenter d'injecter le rôle Principal ou de modifier le compte de Justin.	Blocage applicatif au niveau contrôleur et middleware, journalisation dans l'audit de sécurité.
SEC-03	Exposition de Données (JSON Leaks)	Inspecter le payload brut des réponses de listes et détails avec un profil Secrétaire ou Responsable de zone.	Absence totale des téléphones réels, e-mails et raisons sociales dans la charge utile JSON.
SEC-04	Contournement Territorial (IDOR)	Avec le token du Resp. Zone A, requêter directement l'identifiant d'un bien ou d'une visite de la Zone B.	Rejet immédiat (403 ou 404), aucune fuite d'information sur l'existence de la ressource.
SEC-05	Expiration TTL Démasquage	Interroger l'endpoint des coordonnées 1 seconde après la fin de la période d'approbation (`expires_at`).	Rejet 403 immédiat sans action administrative manuelle préalable.

CODE TEST	SURFACE D'ATTAQUE CIBLÉE	SCÉNARIO DE TEST À EXÉCUTER PAR L'AUDITRICE	RÉSULTAT ATTENDU (CRITÈRE DE SUCCÈS)
SEC-06	Falsification de Webhooks	Envoyer de faux payloads POST sur le webhook KKiaPay (mauvaise signature HMAC, rejeu ou montant altéré).	Rejet des signatures erronées, blocage des doublons (idempotence) et échec de la réconciliation.
SEC-07	Sécurité Retraits & Brute-Force OTP	Tenter d'injecter un compte tiers ou de brute-forcer le code OTP à 6 chiffres.	Ignorance des coordonnées tierces (liste blanche active) et verrouillage strict après 3 tentatives.
SEC-08	Fuite de Données dans les Logs	Déclencher des erreurs de paiement et vérifier les logs consultables par le Super Admin Technique.	Confirmation que montants, soldes et tokens sensibles sont caviardés en `[CONFIDENTIEL_FINANCE]`.
SEC-09	Validité Légale (CGU)	Tenter d'initier un paiement ou une visite sans le paramètre formel d'acceptation des CGU.	Rejet 422 de validation de formulaire avant toute communication avec l'agrégateur.

4. Spécifications des 5 Briques Opérationnelles Complémentaires (Cœur Métier Quotidien)

Les cinq briques suivantes complètent les fondations de sécurité en outillant la **Secrétaire**, les **Responsables de zone** et **Justin MAGNIDE** pour le traitement opérationnel complet du cycle de vie immobilier.

BRIQUE A : Modération du Catalogue & Audit des Titres Fonciers

Cette brique gère le workflow de contrôle qualité et légal des annonces soumises par les agents partenaires ou propriétaires avant diffusion publique.

NOTIONS INDISPENSABLES D'IMPLÉMENTATION BACKEND :

- **Machine à États des Annonces :** Cycle de vie strict du modèle `Proprietes` : `pending_payment` → `pending` (soumis) → `published` (validé) ou `rejected` (rejeté avec motif) → `sold_rented` (conclu) → `archived`.
- **Protection des Pièces Juridiques Foncières (Proprietes_document) :** Les titres fonciers et attestations de recasement ne sont jamais stockés dans un répertoire public. Ils sont consultables uniquement via des flux streamés sécurisés réservés aux Super Admins et à la Secrétaire.
- **Retrait Atomique du Catalogue Public :** Dès le passage à `sold_rented`, l'annonce est instantanément exclue du fil public (`filActualite`) tout en préservant l'intégrité de l'historique comptable et opérationnel.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
GET	`/api/admin/proprietes/en-attente`	Super Admins, Secrétaire, Resp. Zone (Zone)	Liste les biens soumis en attente de modération (avec filtrage automatique par zone pour le Responsable de zone).
POST	`/api/admin/proprietes/{id}/valider`	Super Admins, Secrétaire	Approuve la publication de l'annonce, bascule son état à `published` et notifie l'agent dépositaire.
POST	`/api/admin/proprietes/{id}/rejeter`	Super Admins, Secrétaire	Rejette l'annonce avec motif obligatoire consigné en base et envoyé par notification à l'agent créateur.
POST	`/api/admin/proprietes/{id}/marquer-conclu`	Super Admins, Secrétaire, Resp. Zone (Zone)	Déclare le bien vendu ou loué (`sold_rented`) et le retire du fil d'actualité public.
GET	`/api/admin/proprietes/{id}/documents`	Super Admins, Secrétaire	Génère des URLs de consultation temporaires sécurisées pour examiner les titres fonciers sans permettre le téléchargement libre non tracé.

BRIQUE B : Cycle Opérationnel des Visites Terrain & Comptes-Rendus (Post-Paiement 500 FCFA)

Cette brique organise le relais entre la validation financière d'une visite par KKiaPay et sa prise en charge concrète par les agents de terrain.

NOTIONS INDISPENSABLES D'IMPLÉMENTATION BACKEND :

- **Routage Territorial Automatique :** Dès confirmation du paiement de 500 FCFA, la visite est pré-affectée à la zone géographique du bien concerné.
- **Cycle de Clôture Opérationnelle :** La visite traverse les états : `PAYÉE_À_PLANIFIER` → `PLANIFIÉE` → `EFFECTUÉE` → `CLÔTURÉE` (avec verdict : *Intérêt d'achat confirmé*, *Contre-proposition*, *Sans suite*, *Client absent*).

- **Escalade Commerciale Majeure :** En cas d'intention d'achat formelle constatée sur le terrain, le dossier est escaladé avec alerte prioritaire directe vers MAGNIDE Justin pour engagement des négociations contractuelles.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
POST	`/api/admin/visites/{id}/planifier`	Secrétaire, Resp. Zone (Zone)	Enregistre la date, l'heure et les consignes d'itinéraire de la visite physique, et expédie la convocation au client.
POST	`/api/admin/visites/{id}/compte-rendu`	Resp. Zone (Zone), Secrétaire, Super Admins	Saisit le rapport circonstancié de la visite terrain (remarques du client, points bloquants, validation de l'état du bien).
POST	`/api/admin/visites/{id}/cloturer`	Resp. Zone (Zone), Secrétaire, Super Admins	Clôture le dossier de visite avec motif d'issue normé (`Succès / Offre en cours` , `Sans suite` , `Client absent`).
POST	`/api/admin/visites/{id}/escalader-offre`	Resp. Zone (Zone), Secrétaire	Bascule le dossier en `NÉGOCIATION_HAUTE` et notifie immédiatement Justin MAGNIDE pour suivi commercial direct.

BRIQUE C : Gestion des Demandes de Recherche & Moteur de Rapprochement (Matching)

Cette brique outille les équipes opérationnelles pour convertir les demandes personnalisées des clients en transactions concrètes.

NOTIONS INDISPENSABLES D'IMPLÉMENTATION BACKEND :

- **Prise en Charge Nominale :** Attribution formelle d'une demande de recherche à un gestionnaire afin d'éviter les doubles traitements ou les abandons de dossiers.
- **Moteur de Rapprochement Automatique (Matching Engine) :** Requête SQL multicritères croisant les paramètres de la demande (type de bien, surface min/max, budget plafond, commune, quartier) avec les biens disponibles dans le catalogue.
- **Soumission de Proposition Sécurisée :** Possibilité de rattacher un ou plusieurs biens à la demande du client pour déclencher l'envoi d'une fiche de proposition par notification, sans divulgation des contacts du propriétaire.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
POST	`/api/admin/demandes-clients/{id}/prendre-en-charge`	Secrétaire, Resp. Zone (Zone)	Assigne la demande à l'administrateur connecté et fait évoluer son statut à `en_traitement` .
GET	`/api/admin/demandes-clients/{id}/matching-biens`	Secrétaire, Resp. Zone (Zone), Super Admins	Exécute le matching multicritères entre la demande et les annonces actives du catalogue et calcule un indice de pertinence.
POST	`/api/admin/demandes-clients/{id}/associer-bien`	Secrétaire, Resp. Zone (Zone)	Relie un bien du catalogue au dossier client et expédie une notification de suggestion au demandeur.
POST	`/api/admin/demandes-clients/{id}/cloturer`	Secrétaire, Resp. Zone (Zone), Super Admins	Clôture la recherche (`satisfaite` , `abandonnee_client` , `delai_depasse`).

BRIQUE D : Agrément, Contrôle & KYC des Agents Mobiliers

Cette brique régule les partenaires externes de la plateforme en soumettant leurs privilèges de publication à un agrément formel préalable.

NOTIONS INDISPENSABLES D'IMPLÉMENTATION BACKEND :

- **Statut d'Agrément Professionnel :** Le champ `is_verifed` du modèle `User` conditionne le droit de visibilité publique des annonces déposées.
- **Dossier de Conformité KYC :** Dépôt et contrôle des pièces administratives de l'agent (Registre de Commerce IFU, pièce d'identité certifiée, mandat d'exercice).
- **Révocation & Gel en Cascade :** La suspension d'un compte agent indélicat entraîne automatiquement le déréférencement atomique de toutes ses annonces en ligne pour protéger la réputation d'E-Mobilier.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
GET	`/api/admin/agents-mobiliers`	Super Admins, Secrétaire	Liste l'annuaire des agents mobiliers partenaires avec filtres par statut de vérification KYC (`en_attente` , `verifie` , `suspendu`).
GET	`/api/admin/agents-mobiliers/{id}/dossier`	Super Admins, Secrétaire	Consulte le dossier d'agrément (pièces d'identité, justificatifs d'activité) et l'historique de publication de l'agent.
POST	`/api/admin/agents-mobiliers/{id}/approuver`	Super Admins, Secrétaire	Valide l'agrément de l'agent (`is_verifed = true`), ouvrant le droit de diffusion de ses annonces validées.
POST	`/api/admin/agents-mobiliers/{id}/suspendre`	Super Admins, Secrétaire	Révoque l'agrément de l'agent et bascule immédiatement toutes ses annonces actives à l'état `suspendues` .

BRIQUE E : Tableaux de Bord de Performance Opérationnelle (Non-Financiers)

Cette brique dote les équipes de bordereaux d'activité et d'indicateurs de performance clés (KPIs) opérationnels sans enfreindre le cloisonnement financier.

NOTIONS INDISPENSABLES D'IMPLÉMENTATION BACKEND :

- **Ségrégation Stricte des Métriques :** Les requêtes agrégées de cette brique calculent des volumes, des ratios et des délais temporels en excluant rigoureusement tout champ monétaire (chiffre d'affaires, montants de commissions).
- **Agrégations Pré-calculées en Cache :** Calcul périodique des statistiques d'activité par zone géographique pour garantir des temps de réponse instantanés sur les tableaux de bord.

MÉTHODE	ENDPOINT REST URI	RÔLES AUTORISÉS	COMPORTEMENT BACKEND & RÈGLES DE SÉCURITÉ
GET	`/api/admin/metriques/operations-globales`	Super Admin Principal, Secrétaire	Synthèse opérationnelle : volume de visites du mois, délai moyen de prise en charge, taux de transformation des recherches. **Zéro FCFA.**
GET	`/api/admin/metriques/zone-performance`	Resp. Zone (sa zone), Secrétaire, Super Admins	Métriques sectorielles : taux de complétion des visites terrain, volume d'annonces actives versus vendues sur le secteur.

5. Feuille de Route Consolidée & Séquencement de Développement

Le tableau ci-dessous structure l'ensemble des 10 chantiers (5 Phases Fondations + 5 Briques Métier) par ordre de dépendance technique, avec l'estimation des livrables et des jalons de validation.

JALON	CHANTIER & INTITULÉ	LIVRABLES CLÉS & TRAVAUX BACKEND	CRITÈRE D'ACCEPTATION & RECETTE
Semaine 1	**Phase 1 :** RBAC, Gouvernance, Sanctuarisation & CGU	Refonte 4 rôles, modèle de zones, protection compte Justin, Log Scrubber, signature Charte.	L'Admin Tech ne peut altérer le compte de Justin ; les logs techniques sont purgés.
Semaine 2	**Phase 2 :** Anti-Contournement & Démasquage TTL	Sérialiseurs avec masquage dynamique, scopes par zone, moteur de démasquage temporaire (TTL).	Le flux JSON ne contient aucun contact client pour les secondaires ; expiration stricte du TTL.
Semaine 3	**Phase 3 :** Isolation Financière & KKiaPay	Financial Vault Middleware, webhook idempotent réconcilié, Grand Livre, module de Payout OTP.	Justin est le seul à accéder aux routes financières ; retrait impossible sans OTP valide.
Semaine 4	**Phase 4 :** Notifications Multi-Canal Asynchrones	3 files d'attente de priorités, connecteurs WhatsApp/SMS/Email/Push, repli automatique, audit trail.	Messages différenciés par profil ; bascule immédiate sur SMS si l'API WhatsApp échoue.
Semaine 5	**Briques A & B :** Modération Biens & Visites Terrain	Machine à états du catalogue, sécurité des titres fonciers, planning et rapports post-visite terrain.	Toute visite payée est traçable jusqu'au compte-rendu terrain ; documents fonciers protégés.
Semaine 6	**Briques C, D & E :** Matching, KYC Agents & KPIs	Moteur de croisement des recherches, agrément KYC des agents partenaires, tableaux de bord de vélocité.	Suspension atomique des annonces en cas d'agent révoqué ; KPIs opérationnels sans fuite financière.
Semaine 7	**Phase 5 :** Durcissement & Audit de Sécurité	Intégrité Grand Livre (HMAC Hash Chaining), Tripwire IDS, Kill-Switch, campagne de Pentest de l'auditrice.	Validation formelle des 9 scénarios de test d'intrusion (SEC-01 à SEC-09) avec 100% de conformité.

Conclusion Architecturale : Ce document d'ingénierie clôture de manière définitive et exhaustive l'ensemble des besoins fonctionnels, légaux, de sécurité et d'exploitation métier pour tous les acteurs internes de la plateforme **E-Mobilier**. La base de code backend est désormais prête à être alignée point par point selon cette cartographie.